

TALLER INTENSIVO: OSINT & DFIR

SESIÓN 1: FUNDAMENTOS Y TEORÍA FORENSE

Nivelación Técnica Operativa | Entorno CentruX

I. INTRODUCCIÓN A DFIR

Digital Forensics & Incident
Response

¿QUÉ ES DFIR?



DIGITAL FORENSICS (DF)

La disciplina de identificar, preservar, analizar y presentar evidencia digital de manera legalmente admisible. Es la recolección retrospectiva de datos probatorios tras un evento.



INCIDENT RESPONSE (IR)

El enfoque táctico para gestionar y mitigar brechas de seguridad o ciberataques. Se centra en contener el daño, erradicar la amenaza y recuperar la operatividad (Tiempo Real/Casi Real).



OBJETIVO UNIFICADO

Proveer la verdad técnica e irrefutable. El analista DFIR no asume; correlaciona artefactos para reconstruir la línea de tiempo exacta de una intrusión o incidente cibernético.

“

"Cualquier persona o cosa que entre en una escena del crimen deja algo suyo y se lleva algo de la escena consigo."

”

— EDMOND LOCARD (PRINCIPIO DE INTERCAMBIO)

* En el ámbito digital: Cada ejecución, conexión o acceso deja artefactos, logs o modificaciones en el sistema de archivos y memoria.

EL ROL DEL INVESTIGADOR FORENSE

1. RIGOR TÉCNICO Y CIENTÍFICO

El perito debe emplear herramientas y métodos que sean repetibles y reproducibles. El análisis debe basarse en el método científico, comprobando hipótesis a través del análisis de memoria, disco y red. No hay lugar para la especulación.

2. IMPARCIALIDAD Y OBJETIVIDAD

La misión es descubrir los hechos, no inculpar ni defender a priori. El analista reporta los hallazgos técnicos "tal cual son", manteniendo independencia de sesgos cognitivos o presiones corporativas.

II. CICLO DE VIDA DE LA EVIDENCIA

Estandarización del Procedimiento
Operativo

FASES DEL CICLO FORENSE

2. PRESERVACIÓN/ADQUISICIÓN

Aislamiento y copia bit a bit
(clonado) garantizando
inmutabilidad mediante hashes y
Write Blockers.

4. PRESENTACIÓN

Generación de reportes
ejecutivos y técnicos, admisibles
en tribunales o auditorías de
cumplimiento.

1. IDENTIFICACIÓN

Reconocimiento de activos
físicos y lógicos que contienen
evidencia potencial (Logs,
Dispositivos, Nube).

3. ANÁLISIS

Extracción de artefactos, File
Carving, correlación de eventos y
reconstrucción del Timeline.

FASE 1: TIPOS DE EVIDENCIA



INFRAESTRUCTURA FÍSICA

Discos duros (HDD/SSD), servidores, routers, switches, dispositivos móviles y medios de almacenamiento extraíbles (USB). Requieren secuestro físico y cadena de custodia tradicional.



DATOS VOLÁTILES

Memoria RAM, caché de CPU, tablas de ruteo ARP, conexiones de red activas y procesos en ejecución. Exigen extracción en caliente (Live Forensics) prioritaria.



EVIDENCIA CLOUD/LÓGICA

Instancias EC2, buckets S3, correos electrónicos (O365/Workspace), logs de auditoría remota. La adquisición depende de APIs y herramientas específicas de preservación lógica.

FASE 2: PRESERVACIÓN INMUTABLE

- **Aislamiento Inmediato:** Desconexión de redes para evitar comandos de borrado remoto (Wipe), sin apagar el equipo si se requiere volcar RAM.
- **Uso de Write-Blockers:** Hardware o software diseñado para interceptar comandos de escritura al dispositivo de almacenamiento investigado.
- **Bloqueo por Hardware:** Físicamente corta los pines de escritura en interfaces SATA/NVMe/USB. Es el estándar de oro para admisibilidad.
- **Bloqueo por Software:** Modificación del registro (Ej. Windows WriteProtect) o montaje de particiones en modo estricto Read-Only (RO) en Linux/Centrux.



PARADIGMAS DE ADQUISICIÓN

ADQUISICIÓN FÍSICA (BIT-A-BIT)

Copia exacta del medio de almacenamiento completo, desde el sector 0 hasta el final. Incluye el espacio no asignado (Unallocated Space), Slack Space y archivos eliminados. Es esencial para técnicas de recuperación profunda como el File Carving.

* Formatos comunes: Raw (.dd), EnCase (.e01), AFF4.

ADQUISICIÓN LÓGICA

Extracción exclusiva de archivos y directorios visibles por el sistema operativo, o contenedores lógicos específicos (Ej. una base de datos o un buzón de correo). No permite recuperar datos borrados del disco físico. Se usa cuando la extracción física es imposible técnica o legalmente.

* Formatos comunes: L01, AD1, archivos sueltos hasheados.

III. PRINCIPIOS DE VOLATILIDAD

El factor crítico del tiempo en la
escena

EL ESTÁNDAR RFC 3227

“

"Al recolectar evidencia, se debe proceder desde lo más volátil hacia lo menos volátil."

”

— IETF RFC 3227: GUIDELINES FOR EVIDENCE COLLECTION

Apagar un sistema comprometido ("Pull the plug") destruye la evidencia más crítica: claves de cifrado en memoria, conexiones activas del atacante y malware residente (Fileless).

ORDEN DE VOLATILIDAD (RFC 3227)

Prioridad de Extracción: Siempre capturar RAM (Live Response) antes de interactuar con el disco local para preservar el estado exacto de la intrusión.



ARTEFACTOS VS VOLATILIDAD

Nivel de Volatilidad	Artefactos y Evidencia Potencial	Riesgo de Pérdida al Reiniciar
Extrema (Caché/Registros)	Instrucciones en pipeline, passwords tecleados.	100% Pérdida inmediata
Alta (Memoria RAM)	Malware inyectado, claves de ransomware, procesos ocultos, conexiones TPC/UDP activas.	100% Pérdida al apagar
Media (Sist. de Archivos Temp)	Swap file, pagefile.sys, archivos temporales en memoria compartida (/tmp en tmpfs).	Alta probabilidad de reescritura
Baja (Disco Físico NTFS/EXT4)	Logs de eventos de Windows, Master File Table (MFT), archivos borrados (unallocated).	Persistente. Seguro si se bloquea.

EL FACTOR TIEMPO EN RAM



OPORTUNIDADES SECUNDARIAS

LIVE FORENSICS: UNA SOLA OPORTUNIDAD

Al enfrentarse a un incidente activo (ej. Ransomware en curso), el analista tiene un solo intento para volcar la memoria RAM antes de mitigar. Si el sistema colapsa, se reinicia o se corta la energía por error, toda la telemetría vital sobre cómo operaba el atacante en memoria se pierde irremediablemente. **La preparación del entorno (pendrives forenses) es vital.**

IV. ESTÁNDARES LEGALES

Cadena de Custodia y
Admisibilidad

LA CADENA DE CUSTODIA

DEFINICIÓN FORMAL

Es el procedimiento documentado que garantiza la inalterabilidad y rastreabilidad de la evidencia, desde su identificación en la escena hasta su presentación en un tribunal. Responde a las preguntas: Quién, Qué, Cuándo, Dónde y Cómo operó sobre la prueba.

IMPACTO LEGAL (ADMISIBILIDAD)

Una falla en la cadena de custodia no necesariamente destruye el dato técnico, pero **invalida su uso legal**. Si la defensa demuestra que la evidencia pudo ser alterada (falta de hashes, accesos no documentados), la prueba será declarada nula bajo la "doctrina del fruto del árbol envenenado".

MARCO NORMATIVO REFERENCIAL



LEY 26.388 (ARGENTINA)

Modificatoria del Código Penal que tipifica los delitos informáticos (Daño informático, acceso ilegítimo, interceptación de comunicaciones). Establece la base legal para que la evidencia digital tenga peso probatorio en el país.



CONVENIO DE BUDAPEST

Tratado internacional (Ley 27.411 en Arg) para combatir ciberdelitos. Facilita la cooperación internacional y estandariza procedimientos para la recolección transfronteriza de evidencia electrónica.



ISO/IEC 27037:2012

Estándar internacional de buenas prácticas para la identificación, recolección, adquisición y preservación de evidencia digital. Fundamental para demostrar idoneidad metodológica.

REQUISITOS DE UNA CADENA VÁLIDA



Actas Circunstanciadas: Documento legal que detalla paso a paso la actuación técnica, estado del equipo, conexiones de red halladas y firmas de todos los intervinientes en la escena.



Presencia de Testigos: En allanamientos o secuestros corporativos críticos, la actuación del perito debe estar avalada por testigos hábiles que certifiquen el procedimiento.



Sellado e Identificación Fija: Uso de fajas de seguridad inviolables sobre puertos, carcassas y bolsas antiestáticas de Faraday (para dispositivos móviles).



Validación Criptográfica Inmediata: Cálculo de algoritmos de Hash (Firma Digital) en el momento exacto de la adquisición para "congelar" el estado matemático de la prueba.

PILARES DE ADMISIBILIDAD



AUTENTICIDAD

Demostrar sin lugar a dudas que la evidencia presentada es la misma que fue incautada originalmente en la escena, y que pertenece al caso y dispositivos en cuestión.



INTEGRIDAD

Probar matemáticamente que ni un solo bit de la evidencia ha sido modificado, borrado o añadido desde su recolección. Se certifica mediante comparativas de Hashes.



CONFIABILIDAD

Acreditar que las herramientas y métodos de software utilizados (ej. bloqueadores lógicos en Centrux) son validados por la comunidad forense e incapaces de alterar los datos fuente.

DOCUMENTACIÓN Y EMPAQUE FORENSE

- **Formulario de Cadena de Custodia:** Cada transferencia del dispositivo de una persona a otra debe registrar firma, fecha, hora y motivo del traspaso.
- **Bolsas de Evidencia (Faraday Bags):** Críticas para dispositivos móviles (smartphones, tablets). Bloquean señales celulares, Wi-Fi y Bluetooth.
- **Prevención de Alteración Remota:** Sin el aislamiento de red (Faraday), un atacante podría ejecutar un borrado remoto (Ej. Find My iPhone o MDM corporativo) destruyendo la evidencia antes de llegar al laboratorio.
- **Etiquetado Claro:** Número de caso, fecha de secuestro, descripción del hardware (Marca, Modelo, S/N) adherido al contenedor físico.

PEEL HERE

PEEL HERE

- EVIDENCE -

Submitting Agency: _____

Case No.: _____ Item No.: _____

Date of Collection: _____ Time of Collection: _____

Collected by: _____

Badge No.: _____

Description of Enclosed Evidence: _____

Location Where Collected: _____

Type of Offense: _____

Victim's Full Name: _____

Suspect's Full Name: _____

- CHAIN OF CUSTODY -

Received From: _____

Received By: _____

Date: _____ Time: _____ Signature: _____

Received From: _____

Received By: _____

Date: _____ Time: _____ Signature: _____

Received From: _____

Received By: _____

Date: _____ Time: _____ Signature: _____

FOR FORENSIC LABORATORY PERSONNEL ONLY

Laboratory Number: _____

TRITECH FORENSICS
800.438.7884 • tritechforensics.com

VALIDACIÓN CRIPTOGRÁFICA (HASHES)

Algoritmo	Longitud / Bits	Estado Forense Actual	Uso Práctico Recomendado
MD5	128 bits	Criptográficamente roto (Colisiones)	Triaje rápido, identificación de malware conocido. Legalmente débil por sí solo.
SHA-1	160 bits	Vulnerable a colisiones teóricas	Uso transicional. Se recomienda acompañar siempre de algoritmos superiores.
SHA-256	256 bits	ESTÁNDAR DE LA INDUSTRIA	Generación de firmas legales para actas. Requisito indispensable en peritajes modernos.
SHA-512	512 bits	Altamente seguro	Investigaciones de alta criticidad o seguridad nacional, aunque requiere mayor cómputo.

V. PREPARACIÓN DEL ENTORNO

Laboratorio Operativo:

Centrux

¿QUÉ ES CENTRUX?

EL ENTORNO ANALÍTICO

Centrux es un entorno diseñado con un propósito específico: proporcionar un ecosistema integral de herramientas preconfiguradas para operaciones de OSINT y Análisis Forense, priorizando un entorno de trabajo seguro que ayuda a proteger la integridad de la evidencia durante la investigación

VENTAJA OPERATIVA

Elimina la fricción de dependencias y configuraciones. Permite al analista concentrarse en el análisis (procesar memoria, extraer artefactos, file carving) sin riesgo de contaminar la evidencia debido al montaje seguro nativo (Read-Only).

ARQUITECTURA DEL LABORATORIO



HOST PRINCIPAL

La máquina física del analista.

Debe poseer amplios recursos de almacenamiento (SSD rápidos) y RAM, ya que procesar volcados de memoria y discos enteros requiere gran capacidad de I/O.



SANDBOX (VM)

El entorno Centrux virtualizado.

Las imágenes de evidencia (RAW/E01) se montan en el host y se comparten a la máquina virtual como unidades de "Sólo Lectura".
Aísla el análisis de la red corporativa.



RED AISLADA (AIR-GAPPED)

Cuando se analiza malware dinámicamente o se manipulan artefactos altamente infectados, la máquina virtual debe estar desconectada de adaptadores físicos (Host-Only network) para evitar fugas y movimientos laterales.

HERRAMIENTAS CORE (SESIONES 1-5)

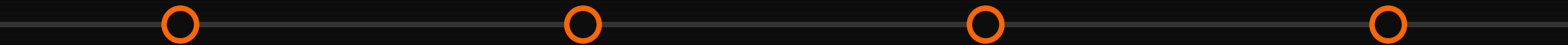
-  **Terminal & Montaje:** Comandos base de Linux (``mount -o ro,loop``, ``fdisk -l``, ``losetup``) para interactuar cruda y seguramente con imágenes forenses DD/RAW.
-  **Adquisición y Hashing:** Utilidades nativas como ``dd``, ``dc3dd``, ``dcfldd`` para clonado sector por sector. ``sha256sum`` para validación criptográfica indispensable.
-  **Forense de RAM: Volatility 3** será nuestra navaja suiza para el análisis de memoria. Extracción de tablas de procesos, netscan y detección de rootkits.
-  **File Carving & Artefactos:** Herramientas estructuradas como ``Scalpel`` y ``Photorec`` para recuperación de datos basándose en estructuras hex (headers/footers) sin depender de tablas de asignación (MFT).

HIGIENE OPERACIONAL (OPSEC)

- **Registro de Comandos:** El analista nunca opera a ciegas. Todo comando ejecutado en la terminal debe registrarse (mediante ``script``, ``tee`` o historial extendido) para los anexos técnicos del reporte final.
- **Directorio de Trabajo Estricto:** Se deben definir rutas específicas (Ej. ``/mnt/evidence`` para lectura, ``/cases/case_01/output`` para resultados). Nunca procesar datos sobre la raíz o mezclar casos.
- **Zero Trust con la Evidencia:** Asuma que cada binario extraído, archivo docx o pdf en un disco comprometido contiene código malicioso. Analice en entornos aislados y jamás los ejecute en su máquina Host.



FLUJO DE INICIO SEGURO



1. SANDBOX

Inicie Centrux con los adaptadores de red en modo Host-Only o deshabilitados.

2. CONEXIÓN R/O

Conecte el disco de evidencia mediante hardware write-blocker al Host o asigne el archivo E01.

3. VALIDACIÓN

Calcule el SHA-256 de la imagen antes de operar y compare con el acta original.

4. MONTAJE

Monte las particiones dentro de Centrux utilizando flags de estricta sólo lectura (-o ro).

RESUMEN Y PRÓXIMOS PASOS

CHECKLIST DE NIVELACIÓN - SESIÓN 1

- ✓ Comprendemos el peso de la Cadena de Custodia.
- ✓ Conocemos el Orden de Volatilidad (RAM > Disco).
- ✓ Establecimos SHA-256 como estándar de validación.
- ✓ Definimos los riesgos de escritura y uso de bloqueadores.

A PREPARARSE PARA SESIÓN 2 (HANDS-ON)

En la próxima sesión dejaremos la teoría.

Ingresaremos a la consola de Centrux, trabajaremos con imágenes DD/RAW reales, ejecutaremos algoritmos de Hash en la terminal y procederemos con montajes de sistemas de archivos defectuosos y particiones lógicas.

PREGUNTAS

FIN SESIÓN 1: FUNDAMENTOS Y TEORÍA (NIVELACIÓN)

Taller Intensivo OSINT & DFIR | Operaciones en Centrux